CYBERSTER RED TEAMING

Network Enumeration & Service Vulnerability Discovery - Week 02

CYBERSTER RED TEAMING

Network Enumeration & Service Vulnerability Discovery - Week 02

DETAIL	INFORMATION
Name	Syed Muhammad Rayyan
Roll No	CSI-BI-620
Internship Program	Cyberster Internship
Task Title	Network Enumeration & Service Vulnerability Discovery
Target Machine	Metasploitable 2 (192.168.0.172)
Engagement Type	Active Reconnaissance & Vulnerability Scanning

---

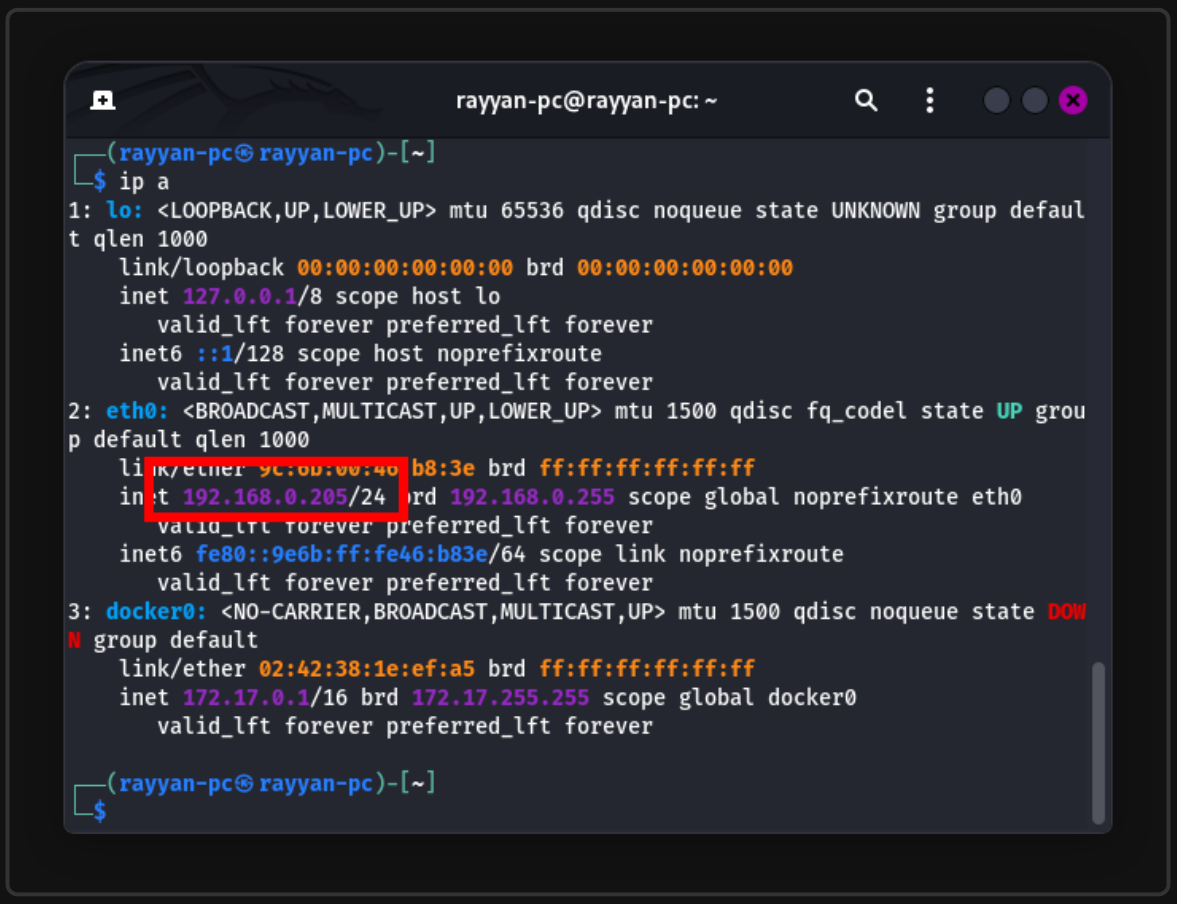
TASK 01: ADVANCED NETWORK SCANNING WITH NMAP

Objective: Transition from broad reconnaissance to targeted network scanning, identifying open ports and fingerprinting services while avoiding basic security triggers.

1.1 Host Discovery & Initial Setup

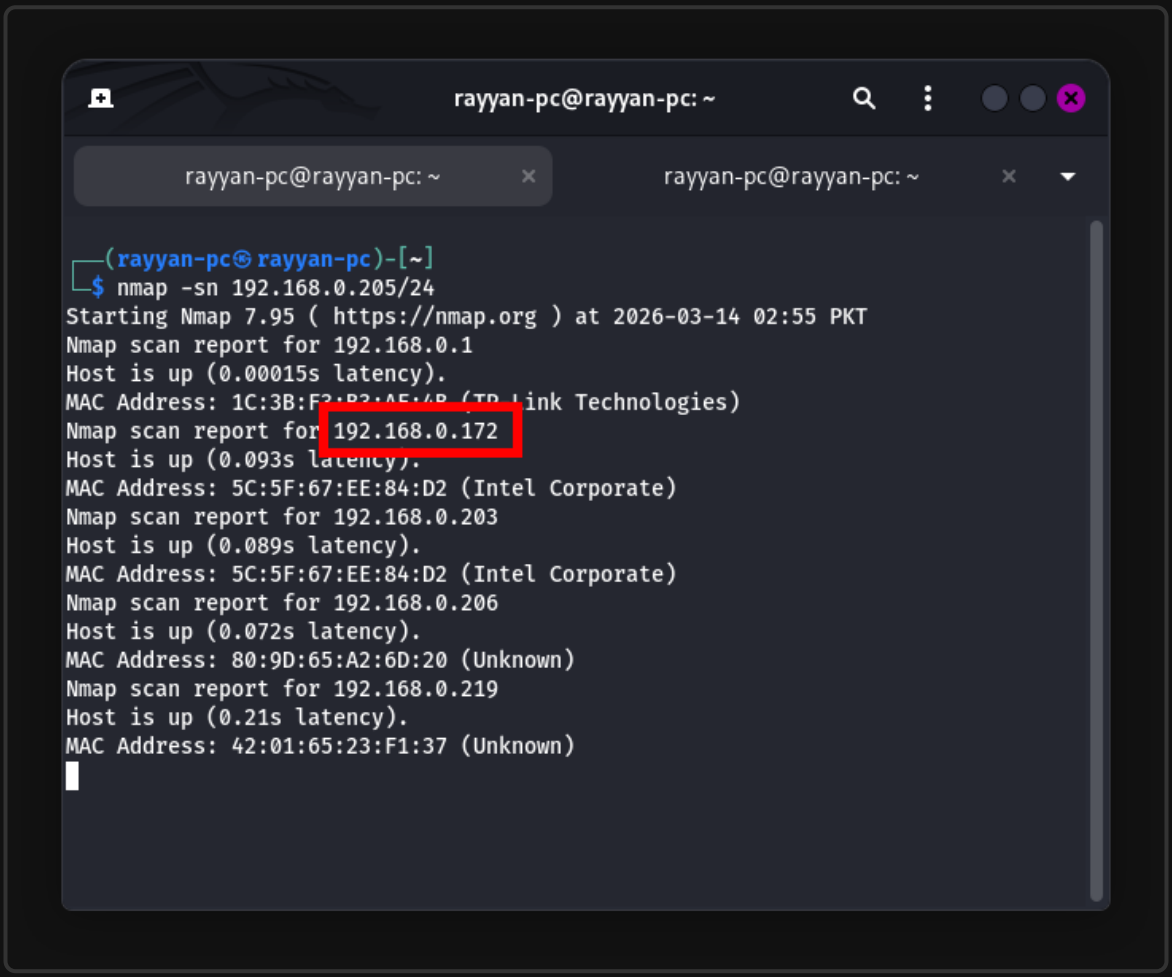
The first step in any engagement is identifying the target's presence on the network. We start by checking our own network configuration and then performing a ping sweep on the local subnet to locate the Metasploitable 2 VM.

```
ifconfig
```



Step 1: Identifying local network interface and gateway configuration.

```
nmap -sn 192.168.0.205/24
```



Step 2: Subnet discovery scan to identify the target IP address (192.168.0.172).

1.2 Comparative Analysis of Scan Techniques

We executed three distinct scan types to analyze their impact on speed and visibility.

TCP Connect Scan (-sT): Completes the full 3-way handshake. Reliable but leaves a larger footprint in application logs.

```
nmap -sT -p 1-1000 -oN results_sT.txt 192.168.0.172
```

```
rayyan-pc@rayyan-pc: ~/Downloads/Github/cyberster/we...

┌──(rayyan-pc㉿rayyan-pc)-[~/Downloads/Github/cyberster/week-2]
└─$ nmap -sT -p 1-1000 -oN results_sT.txt 192.168.0.172
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-14 03:00 PKT
Nmap scan report for 192.168.0.172
Host is up (0.027s latency).
Not shown: 988 closed tcp ports (conn-refused)
PORT    STATE SERVICE
21/tcp  open  ftp
22/tcp  open  ssh
23/tcp  open  telnet
25/tcp  open  smtp
53/tcp  open  domain
80/tcp  open  http
111/tcp open  rpcbind
139/tcp open  netbios-ssn
445/tcp open  microsoft-ds
512/tcp open  exec
513/tcp open  login
514/tcp open  shell
MAC Address: 5C:5F:67:EE:84:D2 (Intel Corporate)

Nmap done: 1 IP address (1 host up) scanned in 7.22 seconds
```

Step 3: Execution of the full TCP 3-way handshake scan.

SYN Stealth Scan (-sS): Sends a SYN packet and waits for a SYN-ACK, then immediately sends a RST. This avoids completing the connection.

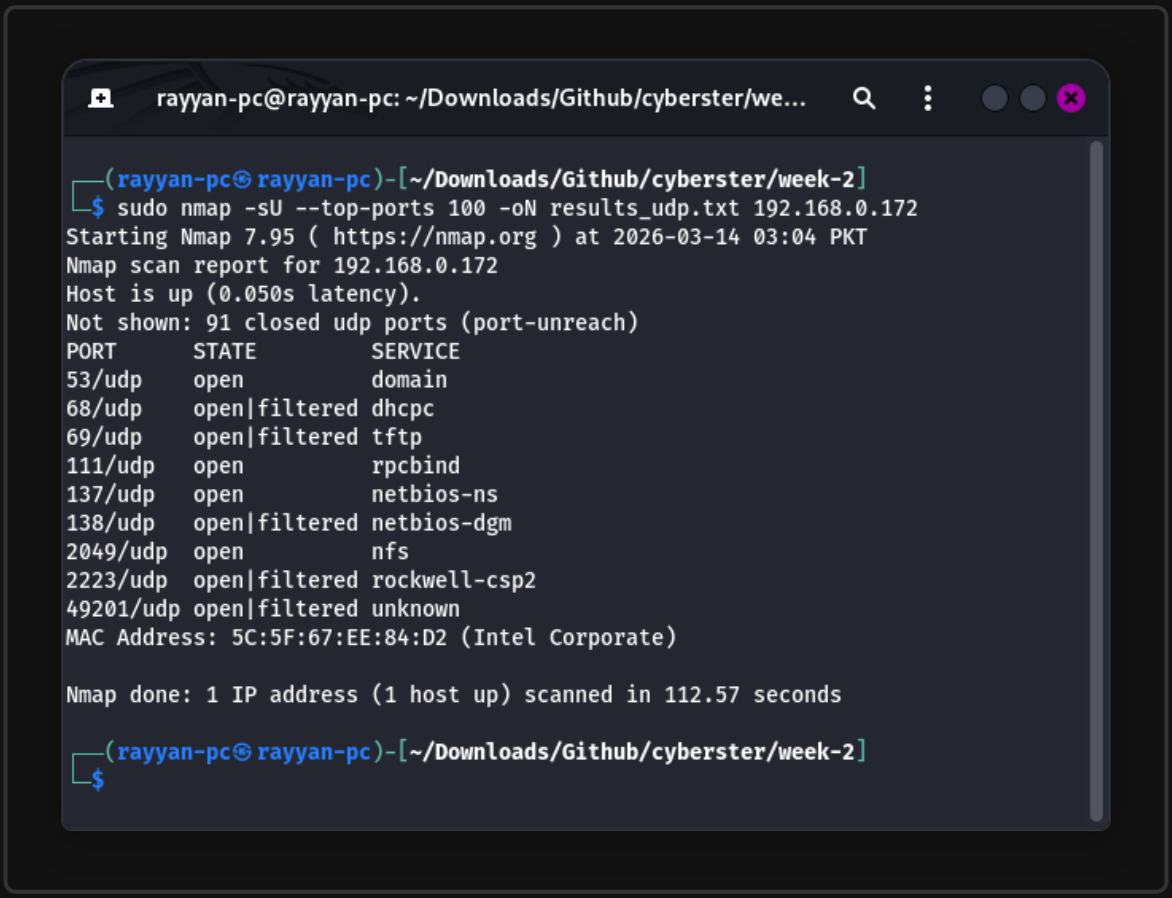
```
sudo nmap -sS -p 1-1000 -oN results_sS.txt 192.168.0.172
```

```
rayyan-pc@rayyan-pc: ~/Downloads/Github/cyberster/we...

┌──(rayyan-pc㉿rayyan-pc)-[~/Downloads/Github/cyberster/week-2]
└─$ sudo nmap -sS -p 1-1000 -oN results_sS.txt 192.168.0.172
[sudo] password for rayyan-pc:
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-14 03:02 PKT
Nmap scan report for 192.168.0.172
Host is up (0.014s latency).
Not shown: 988 closed tcp ports (reset)
PORT     STATE SERVICE
21/tcp   open  ftp
22/tcp   open  ssh
23/tcp   open  telnet
25/tcp   open  smtp
53/tcp   open  domain
80/tcp   open  http
111/tcp  open  rpcbind
139/tcp  open  netbios-ssn
445/tcp  open  microsoft-ds
512/tcp  open  exec
513/tcp  open  login
514/tcp  open  shell
MAC Address: 5C:5F:67:EE:84:D2 (Intel Corporate)

Nmap done: 1 IP address (1 host up) scanned in 13.90 seconds
```

Step 4: Execution of the stealthy half-open SYN scan.

UDP Scan (-sU): Probes stateless ports. Due to the lack of a handshake, this scan is significantly slower as it must wait for timeouts.

```
sudo nmap -sU --top-ports 100 -oN results_udp.txt 192.168.0.172
```



Step 5: Execution of the UDP scan for stateless services.

1.3 Timing Templates Performance

Nmap timing templates control the speed and aggressiveness of the probes.

Polite Template (-T2): Used for maximum stealth to avoid triggering IDS/IPS rate limits.

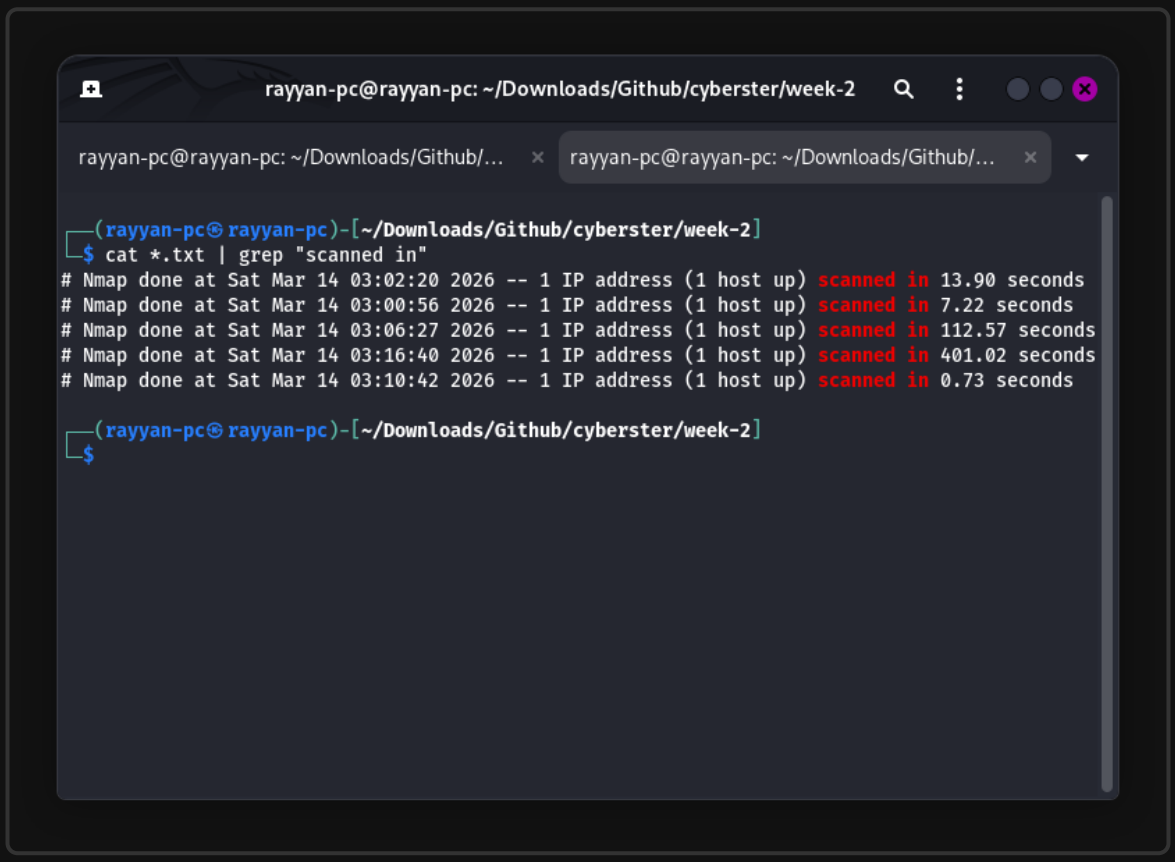
```
sudo nmap -sS -T2 -p 1-1000 -oN sS_T2.txt 192.168.0.172
```

```
rayyan-pc@rayyan-pc: ~/Downloads/Github/cyberster/we...
rayyan-pc@rayyan-pc: ~/Downloads/...   rayyan-pc@rayyan-pc: ~/Downloads/...

┌──(rayyan-pc㉿rayyan-pc)-[~/Downloads/Github/cyberster/week-2]
└─$ sudo nmap -sS -T2 -p 1-1000 -oN sS_T2.txt 192.168.0.172
[sudo] password for rayyan-pc:
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-14 03:09 PKT
Nmap scan report for 192.168.0.172
Host is up (0.066s latency).
Not shown: 988 closed tcp ports (reset)
PORT     STATE SERVICE
21/tcp   open  ftp
22/tcp   open  ssh
23/tcp   open  telnet
25/tcp   open  smtp
53/tcp   open  domain
80/tcp   open  http
111/tcp  open  rpcbind
139/tcp  open  netbios-ssn
445/tcp  open  microsoft-ds
512/tcp  open  exec
513/tcp  open  login
514/tcp  open  shell
MAC Address: 5C:5F:67:EE:84:D2 (Intel Corporate)

Nmap done: 1 IP address (1 host up) scanned in 401.02 seconds
```

Step 6: Polite scan execution (T2) for IDS evasion.

Aggressive Template (-T4): Optimized for speed on stable, fast networks.

```
sudo nmap -sS -T4 -p 1-1000 -oN sS_T4.txt 192.168.0.172
```



Step 7: Aggressive scan (T4) for rapid enumeration.

Comparative Summary: The following table summarizes the time taken for each scanning methodology.

SCAN TYPE	COMMAND FLAG	SCAN DURATION
TCP Connect	-sT	7.22s
SYN Stealth	-sS	13.90s
UDP Scan	-sU	12.57s
Aggressive	-T4	0.73s
Polite	-T2	401.02s

```
rayyan-pc@rayyan-pc: ~/Downloads/Github/cyberster/we...
rayyan-pc@rayyan-pc: ~/Downloads/...   rayyan-pc@rayyan-pc: ~/Downloads/...

┌──(rayyan-pc㉿rayyan-pc)-[~/Downloads/Github/cyberster/week-2]
└─$ sudo nmap -sS -T4 -p 1-1000 -oN sS_T4.txt 192.168.0.172
[sudo] password for rayyan-pc:
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-14 03:10 PKT
Nmap scan report for 192.168.0.172
Host is up (0.030s latency).
Not shown: 988 closed tcp ports (reset)
PORT     STATE SERVICE
21/tcp   open  ftp
22/tcp   open  ssh
23/tcp   open  telnet
25/tcp   open  smtp
53/tcp   open  domain
80/tcp   open  http
111/tcp  open  rpcbind
139/tcp  open  netbios-ssn
445/tcp  open  microsoft-ds
512/tcp  open  exec
513/tcp  open  login
514/tcp  open  shell
MAC Address: 5C:5F:67:EE:84:D2 (Intel Corporate)

Nmap done: 1 IP address (1 host up) scanned in 0.73 seconds
```

Step 8: Consolidated view of scan timings and efficiency.

TASK 02: SERVICE FINGERPRINTING & ATTACK SURFACE MAPPING

Objective: Identify exact software versions to map against known vulnerabilities and exploit databases.

2.1 Version Detection & Aggressive Scanning

Using version detection (-sV) probes open ports to extract service headers and determine the exact software version. The aggressive scan (-A) combines this with OS fingerprinting and default script execution.

```
nmap -sV 192.168.0.172 -oN results_sV.txt
```

```
┌──(rayyan-pc㉿rayyan-pc)-[~/Downloads/Github/cyberster/week-2]
└─$ nmap -sV 192.168.0.172
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-14 03:18 PKT
Nmap scan report for 192.168.0.172
Host is up (0.022s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
53/tcp   open  domain      ISC BIND 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp  open  rpcbind     2 (RPC #100000)
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp  open  exec        netkit-rsh rexecd
513/tcp  open  login       OpenBSD or Solaris rlogind
514/tcp  open  tcpwrapped
1099/tcp open  java-rmi    GNU Classpath grmiregistry
1524/tcp open  bindshell   Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp open  vnc         VNC (protocol 3.3)
6000/tcp open  X11         (access denied)
6667/tcp open  irc         UnrealIRCd
8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)
8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 5C:5F:67:EE:84:D2 (Intel Corporate)
Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; C
PE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/
.
Nmap done: 1 IP address (1 host up) scanned in 12.36 seconds

┌──(rayyan-pc㉿rayyan-pc)-[~/Downloads/Github/cyberster/week-2]
└─$
```

Step 9: Identifying specific versions like vsFTPd 2.3.4 and Apache 2.2.8.

```
nmap -A 192.168.0.172 -oN results_A.txt
```

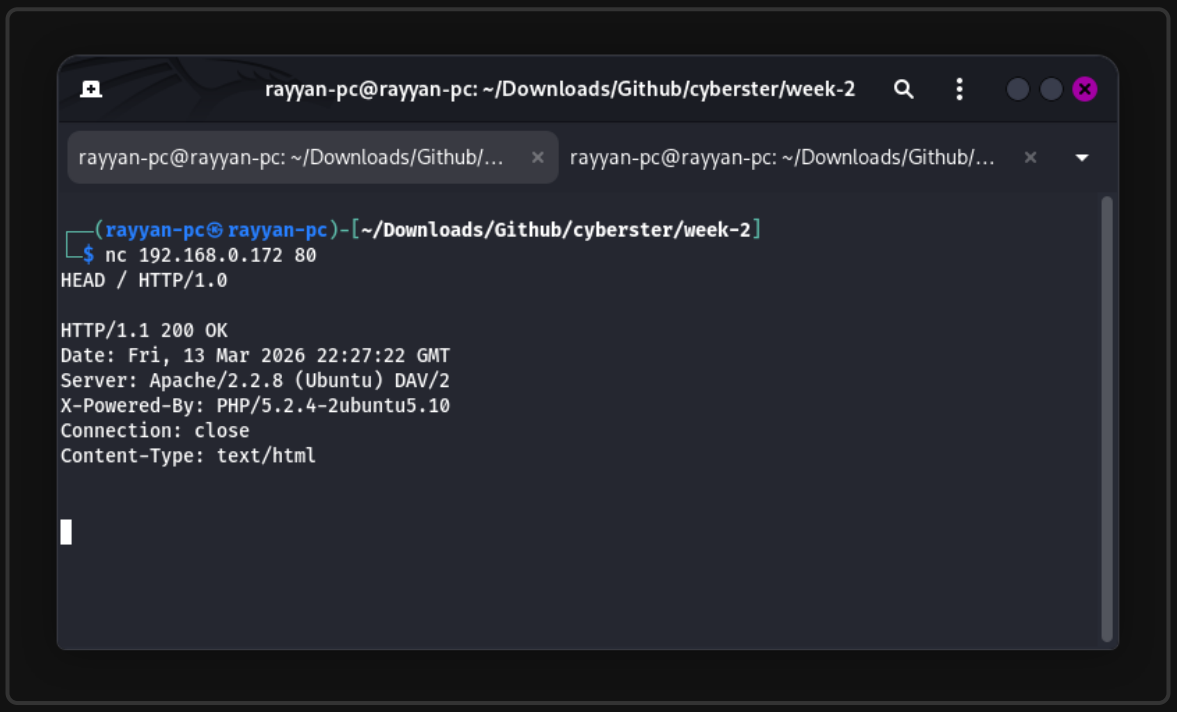
```
rayyan-pc@rayyan-pc: ~/Downloads/Github/cyberster/week-2

┌──(rayyan-pc㉿rayyan-pc)-[~/Downloads/Github/cyberster/week-2]
└─$ nmap -A 192.168.0.172
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-14 03:21 PKT
Nmap scan report for 192.168.0.172
Host is up (0.0085s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to 192.168.0.205
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      vsFTPd 2.3.4 - secure, fast, stable
|_End of status
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
| sslv2:
|   SSLv2 supported
|   ciphers:
|     SSL2_RC2_128_CBC_WITH_MD5
|     SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|     SSL2_DES_64_CBC_WITH_MD5
|     SSL2_RC4_128_EXPORT40_WITH_MD5
|     SSL2_DES_192_EDE3_CBC_WITH_MD5
|_    SSL2_RC4_128_WITH_MD5
| ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProv
inceName=There is no such thing outside US/countryName=XX
| Not valid before: 2010-03-17T14:07:45
|_Not valid after:  2010-04-16T14:07:45
|_smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS,
```

Step 10: OS detection and script scanning results confirming Linux environment.

2.2 Manual Banner Grabbing

Manual verification is essential to confirm automated results. We use Netcat to manually connect and retrieve service banners.

```
nc 192.168.0.172 80
HEAD / HTTP/1.0
```

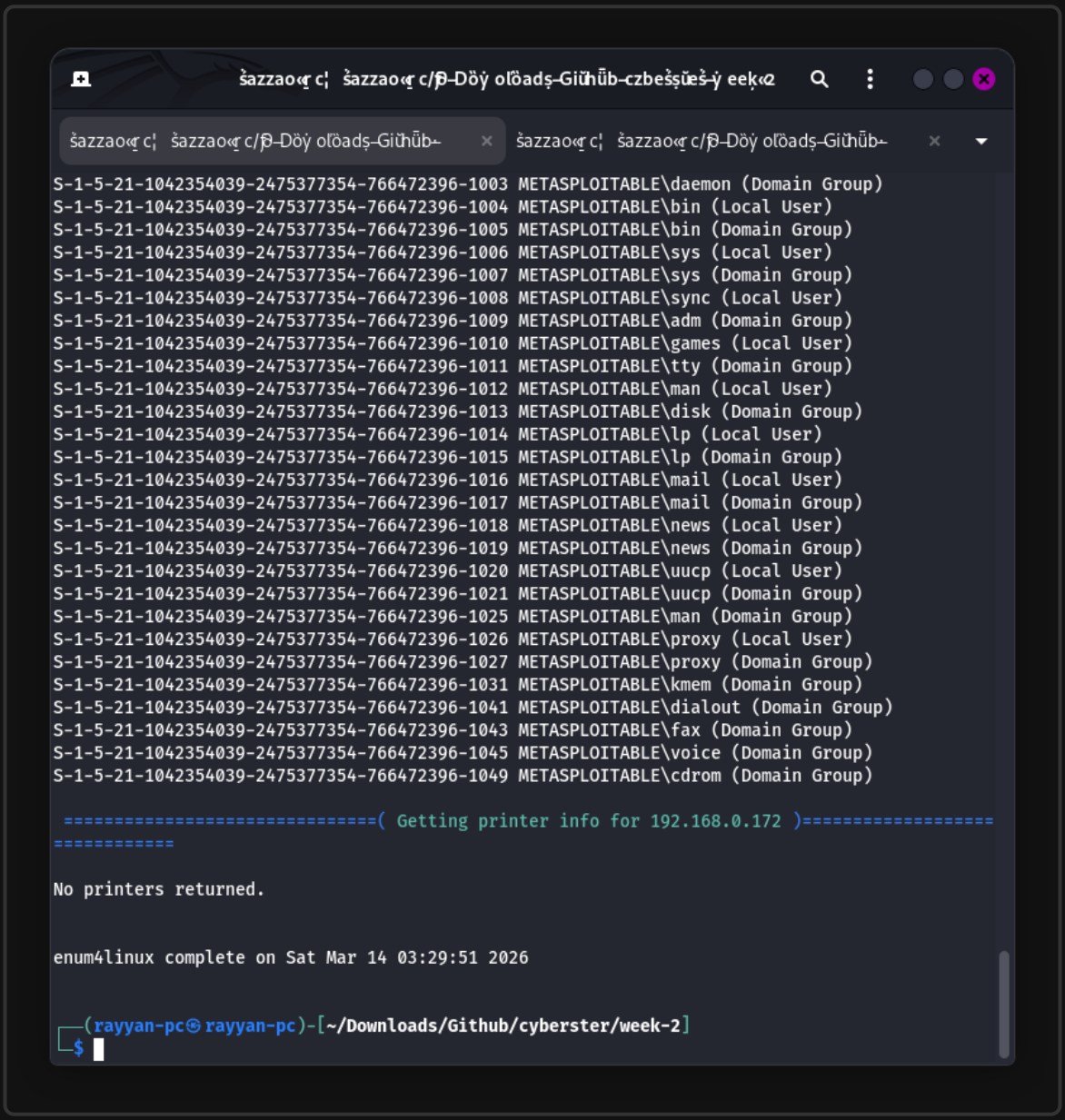


Step 11: Manually extracting the Apache web server banner via Netcat.

2.3 SMB Enumeration

Ports 139 and 445 (Samba) often reveal critical information about the target's internal structure.

```
enum4linux -a 192.168.0.172
```



Step 12: Successful unauthenticated SMB session revealing user accounts and shares.

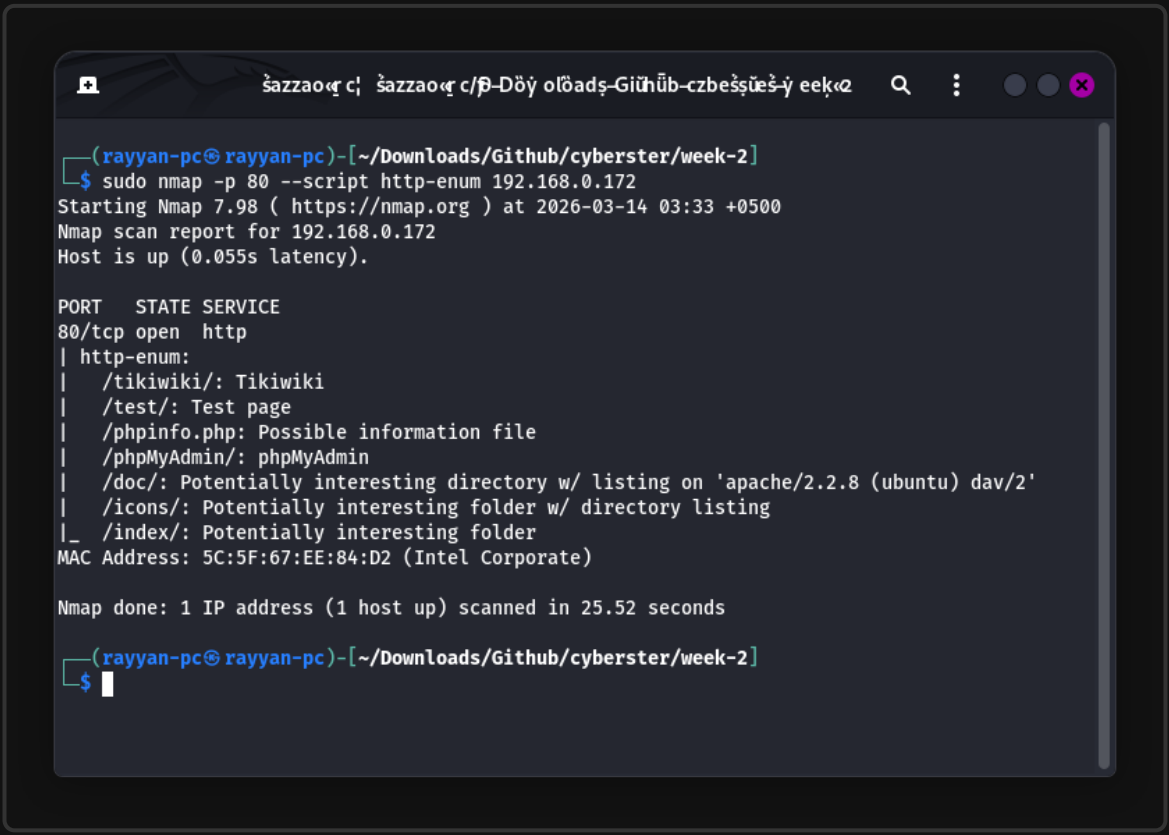
TASK 03: LEVERAGING NMAP SCRIPTING ENGINE (NSE)

Objective: Automate vulnerability detection using the built-in Nmap Scripting Engine categories.

3.1 HTTP Enumeration & Path Discovery

NSE scripts can automate directory brute-forcing to find hidden configuration files or admin panels.

```
sudo nmap -p 80 --script http-enum 192.168.0.172
```

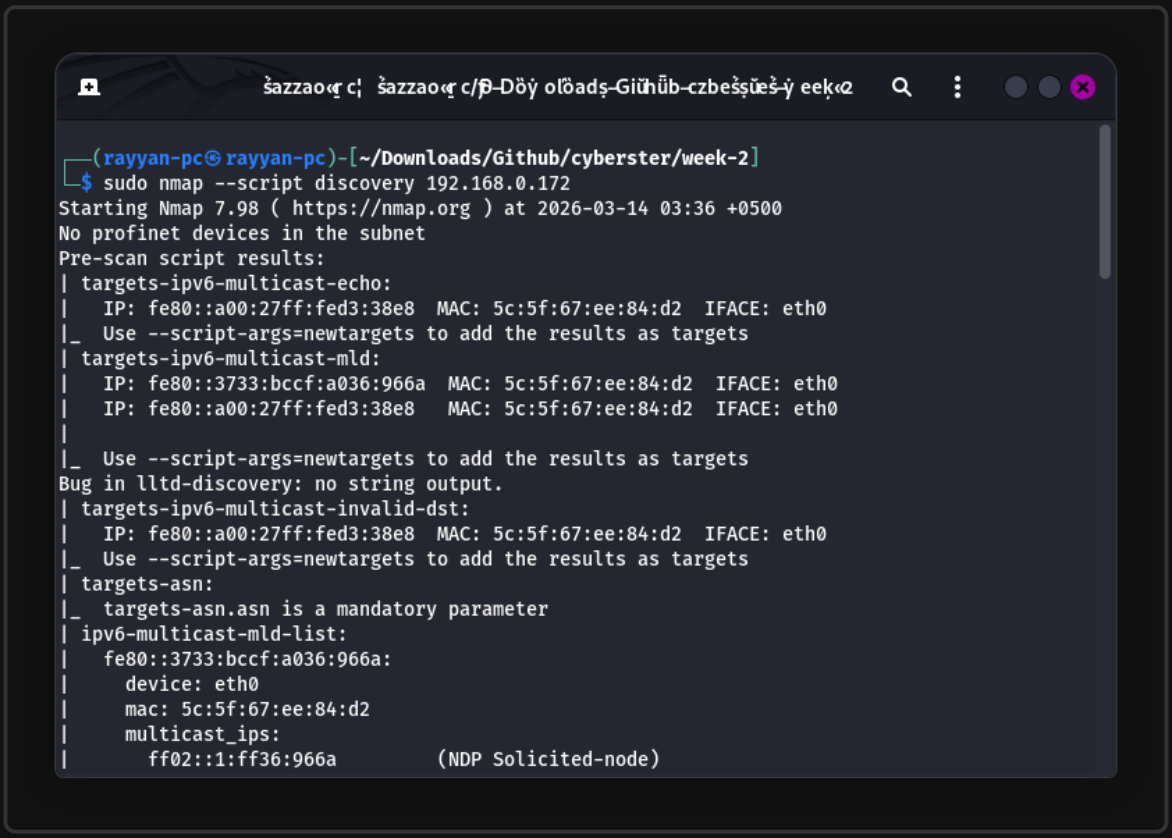


Step 13: Finding sensitive paths such as /phpinfo.php and /phpMyAdmin/.

3.2 Network Discovery Scripts

The 'discovery' category probes for a wide range of network information, including DNS, SNMP, and SMB details.

```
sudo nmap --script discovery 192.168.0.172
```



```
┌──(rayyan-pc㉿rayyan-pc)-[~/Downloads/Github/cyberster/week-2]
└─$ sudo nmap --script discovery 192.168.0.172
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-14 03:36 +0500
No profinet devices in the subnet
Pre-scan script results:
| targets-ipv6-multicast-echo:
|   IP: fe80::a00:27ff:fed3:38e8  MAC: 5c:5f:67:ee:84:d2  IFACE: eth0
|_  Use --script-args=newtargets to add the results as targets
| targets-ipv6-multicast-mld:
|   IP: fe80::3733:bccf:a036:966a  MAC: 5c:5f:67:ee:84:d2  IFACE: eth0
|   IP: fe80::a00:27ff:fed3:38e8   MAC: 5c:5f:67:ee:84:d2  IFACE: eth0
|
|_  Use --script-args=newtargets to add the results as targets
Bug in lltd-discovery: no string output.
| targets-ipv6-multicast-invalid-dst:
|   IP: fe80::a00:27ff:fed3:38e8  MAC: 5c:5f:67:ee:84:d2  IFACE: eth0
|_  Use --script-args=newtargets to add the results as targets
| targets-asn:
|_  targets-asn.asn is a mandatory parameter
| ipv6-multicast-mld-list:
|   fe80::3733:bccf:a036:966a:
|     device: eth0
|     mac: 5c:5f:67:ee:84:d2
|     multicast_ips:
|       ff02::1:ff36:966a        (NDP Solicited-node)
```

Step 14: Broad discovery scripts revealing network-level configurations.

3.3 Vulnerability Identification

The 'vuln' category checks for specific, known exploits based on the identified service versions.

```
sudo nmap --script vuln 192.168.0.172
```

```
rayyan-pc@rayyan-pc: ~/Downloads/Github/cyberster/we...

┌──(rayyan-pc㉿rayyan-pc)-[~/Downloads/Github/cyberster/week-2]
└─$ sudo nmap --script vuln 192.168.0.172
[sudo] password for rayyan-pc:
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-14 03:48 +0500
Nmap scan report for 192.168.0.172
Host is up (0.011s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE
21/tcp   open  ftp
| ftp-vsftpd-backdoor:
|   VULNERABLE:
|   vsFTPd version 2.3.4 backdoor
|     State: VULNERABLE (Exploitable)
|     IDs:  BID:48539  CVE:CVE-2011-2523
|       vsFTPd version 2.3.4 backdoor, this was reported on 2011-07-04.
|     Disclosure date: 2011-07-03
|     Exploit results:
|       Shell command: id
|       Results: uid=0(root) gid=0(root)
|     References:
|       http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-bac
kdoored.html
|       https://github.com/rapid7/metasploit-framework/blob/master/modules/explo
```

Step 15: Critical vulnerability detection results mapping to specific CVE IDs.

Service Vulnerability Mapping:

PORT	SERVICE	VULNERABILITY	CVE ID	RISK LEVEL
21	FTP	vsFTPd 2.3.4 Backdoor	CVE-2011-2523	Critical
25	SMTP	SSL POODLE	CVE-2014-3566	Medium
80	HTTP	Slowloris DoS	CVE-2007-6750	High
5432	PostgreSQL	CCS Injection	CVE-2014-0224	Medium
6667	IRC	UnrealIRCd Trojan	CVE-2010-2075	Critical
1524	Shell	Bindshell Root Access	N/A	Critical

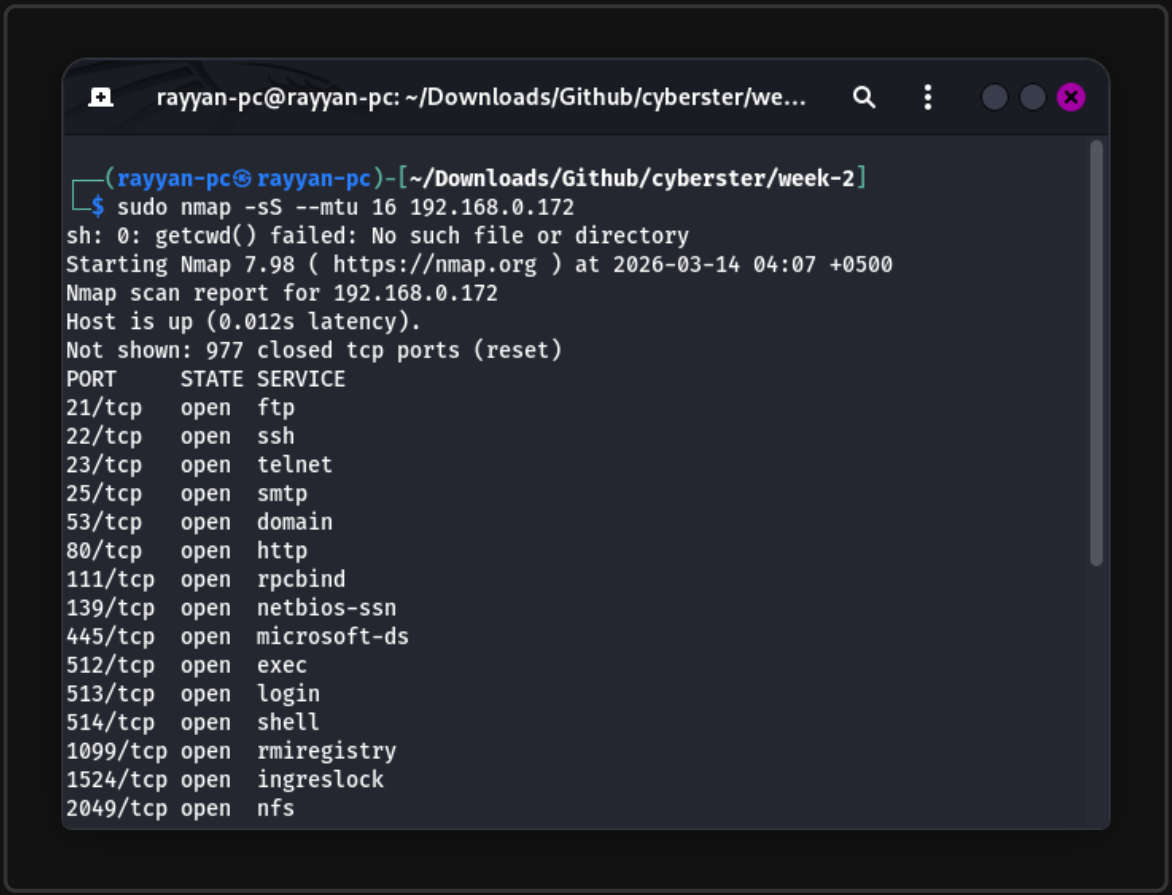
TASK 04: STEALTH & FIREWALL EVASION TECHNIQUES

Objective: Employ packet manipulation and traffic masking to bypass basic network security filters.

4.1 MTU Manipulation

Changing the Maximum Transmission Unit (MTU) forces the network stack to fragment packets in non-standard sizes, which can evade simple signature-based packet inspection.

```
sudo nmap -sS --mtu 16 192.168.0.172
```



Step 16: Scanning with a specific MTU of 16 to bypass size-based packet filters.

4.2 Source Port Spoofing

Firewalls often allow traffic from "trusted" ports. We can disguise our scan as standard DNS traffic by originating it from Port 53.

```
sudo nmap -sS --source-port 53 192.168.0.172
```

```
rayyan-pc@rayyan-pc: ~/Downloads/Github/cyberster/we...

┌──(rayyan-pc㉿rayyan-pc)-[~/Downloads/Github/cyberster/week-2]
└─$  sudo nmap -sS --source-port 53 192.168.0.172
sh: 0: getcwd() failed: No such file or directory
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-14 04:11 +0500
Nmap scan report for 192.168.0.172
Host is up (0.019s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE
21/tcp   open  ftp
22/tcp   open  ssh
23/tcp   open  telnet
25/tcp   open  smtp
53/tcp   open  domain
80/tcp   open  http
111/tcp  open  rpcbind
139/tcp  open  netbios-ssn
445/tcp  open  microsoft-ds
512/tcp  open  exec
513/tcp  open  login
514/tcp  open  shell
1099/tcp open  rmiregistry
1524/tcp open  ingreslock
2049/tcp open  nfs
```

Step 17: Disguising scan traffic as DNS queries to bypass port-specific filters.

ACTIONABLE INSIGHTS & CONCLUSION

The most critical "Initial Access" point identified is the **vsFTPd 2.3.4 Backdoor (CVE-2011-2523)** on Port 21. This vulnerability allows for immediate, unauthenticated root access. Combined with the **Unauthenticated Bindshell on Port 1524**, the target machine is highly susceptible to full compromise.

Recommendations: 1. **Immediate Remediation:** Disable or update the vsFTPd service and remove the unauthenticated bindshell on Port 1524. 2. **Service Hardening:** Update Apache (Port 80) and PostgreSQL (Port 5432) to mitigate the Slowloris and CCS injection vulnerabilities. 3. **Network Security:** Implement strict firewall ingress/egress rules to prevent unauthenticated access to database and administrative services.

Date: March 14, 2026 **Classification:** Training / Authorized Engagement